

NAME: Alex Mbogo
GMAIL: evansnjiru5@gmail.com
ADMISSION NUMBER: ADC-CSS02-25064

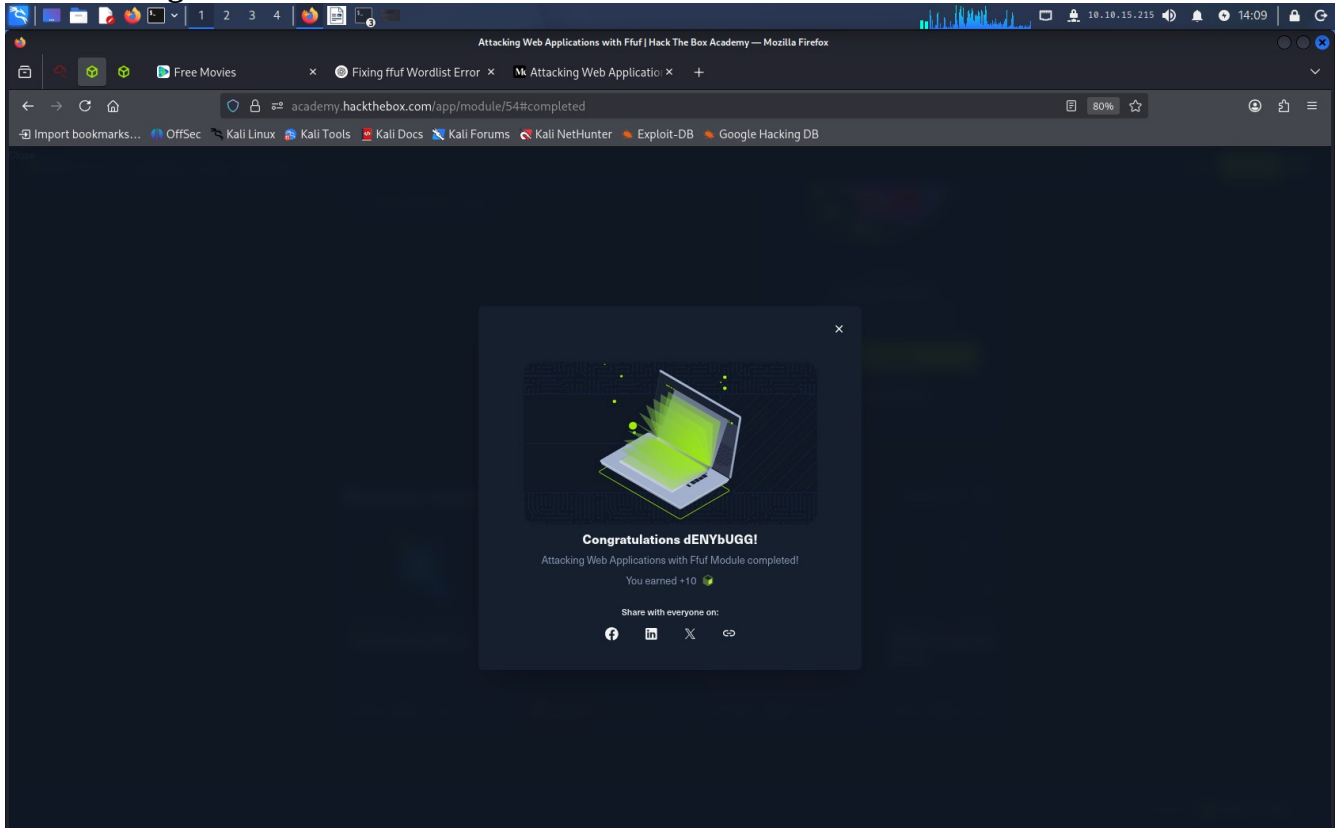
Module: Attacking Web Applications with Ffuf

Module link

<https://academy.hackthebox.com/achievement/1378833/54>

Module Badge

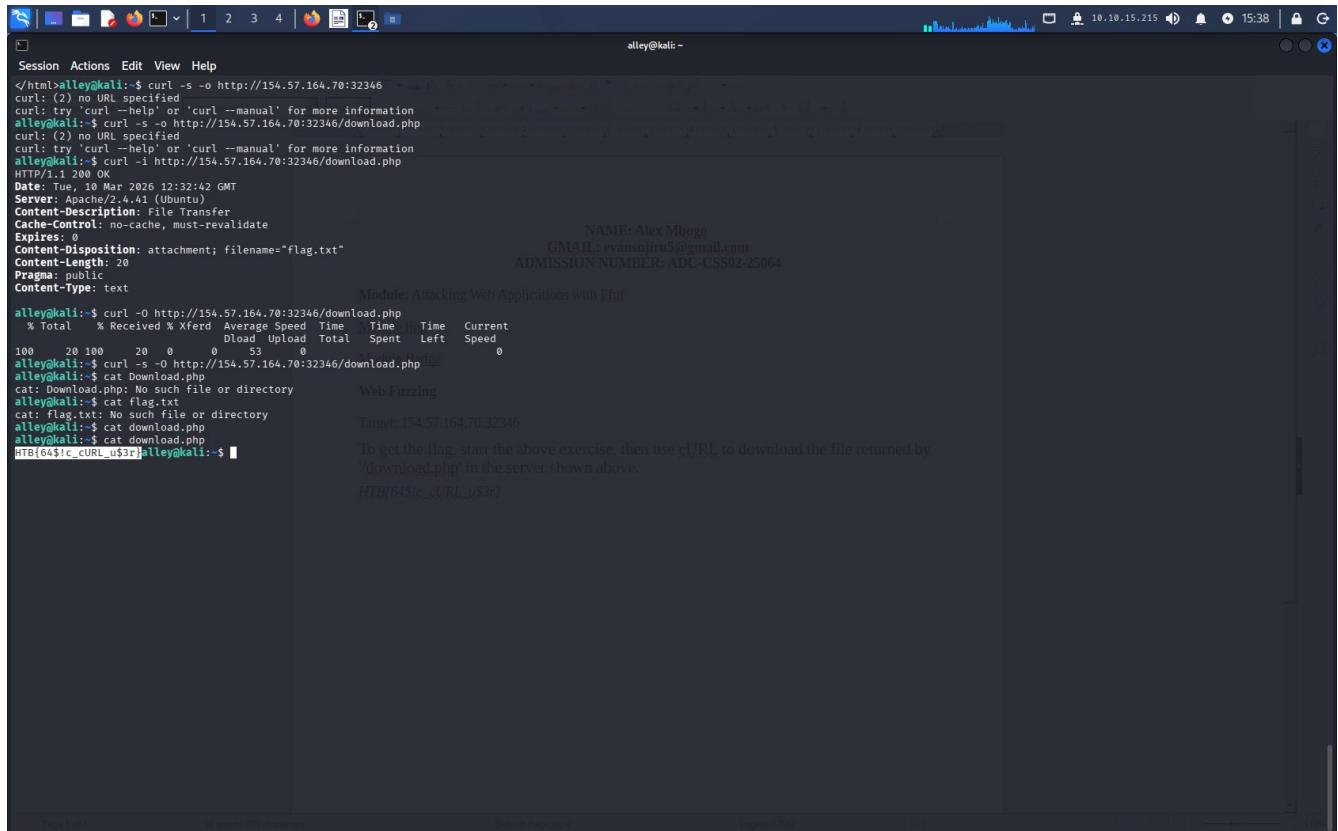
Web Fuzzing



Target: 154.57.164.70:32346

To get the flag, start the above exercise, then use cURL to download the file returned by '/download.php' in the server shown above.

HTB{64\$c_cURL_u\$3r}



```
alley@kali: ~  
</html>alley@kali:~$ curl -s -o http://154.57.164.70:32346  
curl: (2) no URL specified  
alley@kali:~$ curl -s -o http://154.57.164.70:32346/download.php  
curl: (2) no URL specified  
alley@kali:~$ curl -i http://154.57.164.70:32346/download.php  
HTTP/1.1 200 OK  
Date: Tue, 10 Mar 2026 12:32:42 GMT  
Server: Apache/2.4.42 (Ubuntu)  
Content-Description: File Transfer  
Cache-Control: no-cache, must-revalidate  
Expires: 0  
Content-Disposition: attachment; filename="flag.txt"  
Content-Length: 28  
Pragma: public  
Content-Type: text  
NAME: Alex Mhoge  
GMAIL: evansjira@gmail.com  
ADMISSION NUMBER: ADC-CSS02-25064  
Module: Attacking Web Applications with Flag  
alley@kali:~$ curl -O http://154.57.164.70:32346/download.php  
% Total % Received % Xferd Average Speed Time Time Current  
Dload Upload Total Spent Left Speed  
100 20 100 20 0 0 53 0 0 0 0 0  
alley@kali:~$ curl -s -o http://154.57.164.70:32346/download.php  
alley@kali:~$ cat download.php  
cat: download.php: No such file or directory  
alley@kali:~$ cat flag.txt  
cat: flag.txt: No such file or directory  
alley@kali:~$ cat download.php  
alley@kali:~$ cat download.php  
HTB{64$c_cURL_u$3r}alley@kali:~$
```

HTTP Fundamentals

- Protocol Role: An application-level protocol used to access resources on the World Wide Web.
- Client-Server Model: A client (browser/tool) sends a request for a resource, and the server processes it and returns a response.
- Default Ports: Port 80 for HTTP and 443 for HTTPS.
- DNS Resolution: Before a request is sent, the browser resolves the Domain Name (e.g., google.com) into an IP address via a DNS server or the local /etc/hosts file.

2. URL Structure

Resources are accessed via a Uniform Resource Locator (URL), which consists of several components (some optional):

- Scheme: The protocol (e.g., http://).
- User Info: Optional credentials (user:password@).
- Host: The resource location (domain or IP).
- Port: Specified after a colon (e.g., :8080).
- Path: The specific file or directory (e.g., /index.html).
- Query String: Parameters for the server (e.g., ?id=1).
- Fragment: Client-side anchors to specific page sections (e.g., #top).

3. cURL (Client URL)

The text highlights **cURL** as a vital command-line tool for penetration testing and automation. Unlike browsers, cURL displays the raw source code (HTML/CSS) of a response.

- **Key Commands:**
 - curl [URL]: Fetches and prints the resource to the terminal.
 - -O: Saves the file using its remote name.
 - -o [filename]: Saves the file with a custom name.
 - -s: Silent mode (hides progress bars).
 - -v / -i: Verbose mode/Include headers (useful for debugging).

4. The Request Flow

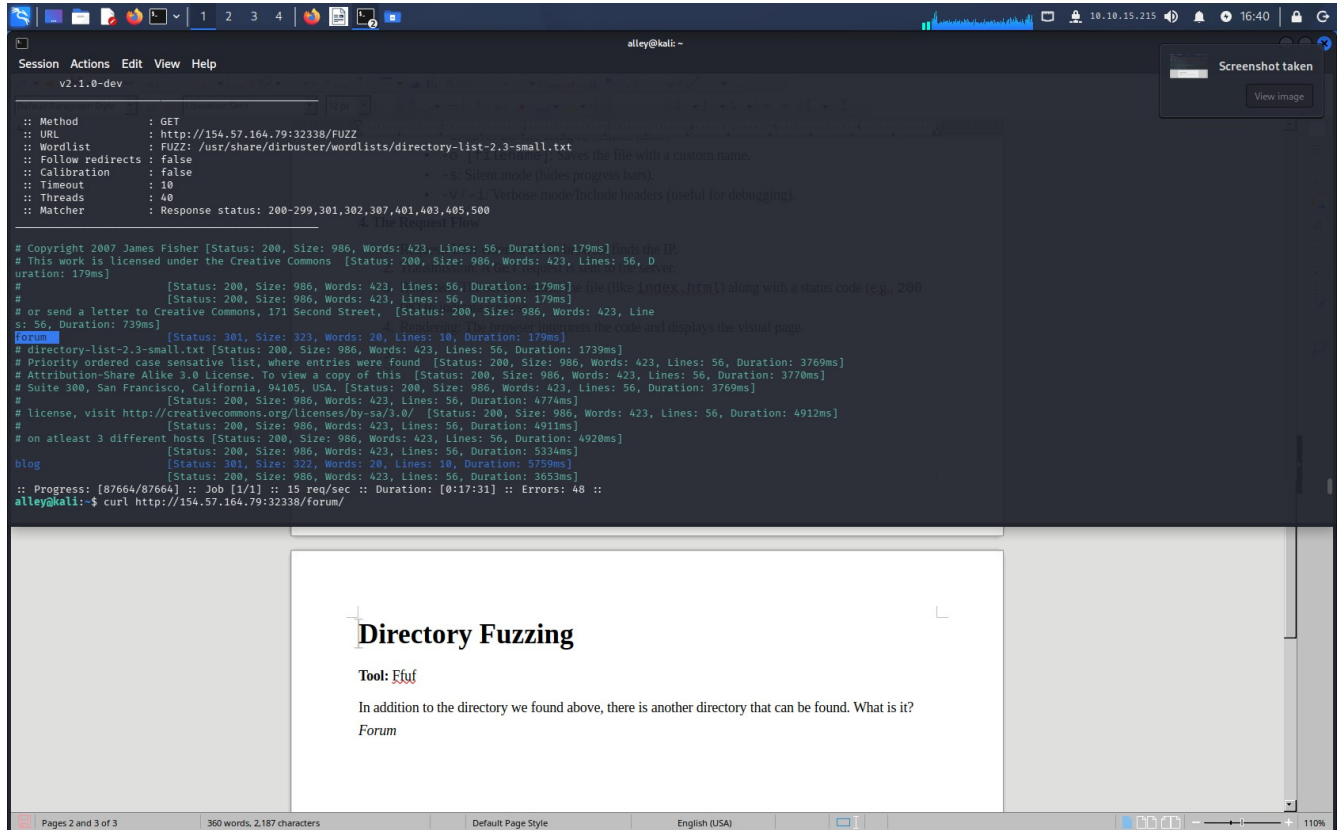
1. Request: User enters a URL; browser finds the IP.
2. Transmission: A GET request is sent to the server.
3. Response: The server returns the file (like index.html) along with a status code (e.g., 200 OK) to indicate success.
4. Rendering: The browser interprets the code and displays the visual page.

Directory Fuzzing

Tool: Ffuf

In addition to the directory we found above, there is another directory that can be found. What is it?

Forum



Page Fuzzing

Try to use what you learned in this section to fuzz the '/blog' directory and find all pages. One of them should contain a flag. What is the flag?

HTB{bru73_f0r_c0mm0n_p455w0rd5}

```
Session Actions Edit View Help
[Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 182ms]
:: Progress: [87664/87664] :: Job [1/1] :: 35 req/sec :: Duration: [0:08:50] :: Errors: 6 ::
alleg@kali:~$ curl -u http://154.57.164.81:30663/blog/FUZZ.php \
-u http://154.57.164.81:30663/blog/FUZZ.php \
-ac -c
v2.1.0-dev

:: Method      : GET
:: URL         : http://154.57.164.81:30663/blog/FUZZ.php
:: Wordlist    : FUZZ: /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt
:: Follow redirects : false
:: Calibration : true
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

# Copyright 2007 James Fisher [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 177ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 177ms]
# directory-list-2.3-small.txt [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 178ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 272ms]
# Suite 300, San Francisco, California, 94105, USA, [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 272ms]
# Attribution-Share Alike 3.0 license. To view a copy of this [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 373ms]
# This work is licensed under the Creative Commons [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 373ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 373ms]
# Priority ordered case sensitive list, where entries were found [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 473ms]
# or send a letter to creative commons, 171 Second Street, [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 473ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 473ms]
# on atleast 3 different hosts [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 473ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 474ms]
# Index [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 474ms]
:: Progress: [87664/87664] :: Job [1/1] :: 170 req/sec :: Duration: [0:11:18] :: Errors: 21 ::
alleg@kali:~$ curl http://154.57.164.81:30663/blog/home.php -o file.txt
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left   Speed
100 1046 100 1046 0    0 2840 0      0      0      0      0
alleg@kali:~$ cat home.php
cat: home.php: No such file or directory
alleg@kali:~$ ls
backup_credentials.txt  Desktop  download.php  exploit.py  hash.txt  index.html.1  kerbrute_linux_amd64  packages.microsoft.gpg  Projects  Templates  wordlist.txt
curl_response          Documents Downloads  file.txt    index.html  kerbrute      Music              Pictures          Public      Videos
alleg@kali:~$ cat file.txt
<html>
<!DOCTYPE html>

<head>
<title>HTB Academy</title>
<style>
*,
html {
margin: 0;
padding: 0;
border: 0;
}

html {
width: 100%;
height: 100%;
}

body {
width: 100%;
height: 100%;
position: relative;
background-color: orange;
}

.center {
width: 100%;
height: 50%;
margin: 0;
position: absolute;
top: 50%;
left: 50%;
transform: translate(-50%, -50%);
color: white;
font-family: "Helvetica", Helvetica, sans-serif;
text-align: center;
}

h1 {
font-size: 144px;
}

p {
font-size: 64px;
}
</style>
</head>

<body>
<div class="center">
<h1>Admin panel moved to academy.htb</h1>
<br>
```

```
Session Actions Edit View Help
100 1046 100 1046 0 0 2840 0 0
alleg@kali:~$ cat home.php
cat: home.php: No such file or directory
alleg@kali:~$ ls
backup_credentials.txt  Desktop  download.php  exploit.py  hash.txt  index.html.1  kerbrute_linux_amd64  packages.microsoft.gpg  Projects  Templates  wordlist.txt
curl_response          Documents Downloads  file.txt    index.html  kerbrute      Music              Pictures          Public      Videos
alleg@kali:~$ cat file.txt
<html>
<!DOCTYPE html>

<head>
<title>HTB Academy</title>
<style>
*,
html {
margin: 0;
padding: 0;
border: 0;
}

html {
width: 100%;
height: 100%;
}

body {
width: 100%;
height: 100%;
position: relative;
background-color: orange;
}

.center {
width: 100%;
height: 50%;
margin: 0;
position: absolute;
top: 50%;
left: 50%;
transform: translate(-50%, -50%);
color: white;
font-family: "Helvetica", Helvetica, sans-serif;
text-align: center;
}

h1 {
font-size: 144px;
}

p {
font-size: 64px;
}
</style>
</head>

<body>
<div class="center">
<h1>Admin panel moved to academy.htb</h1>
<br>
```

```
alley@kali:~$ cat file.txt
<html>
<!DOCTYPE html>

<head>
  <title>HTB Academy</title>
  <style>
    *,
    html {
      margin: 0;
      padding: 0;
      border: 0;
    }

    html {
      width: 100%;
      height: 100%;
    }

    body {
      width: 100%;
      height: 100%;
      position: relative;
      background-color: orange;
    }

    .center {
      width: 100%;
      height: 50%;
      margin: 0;
      position: absolute;
      top: 50%;
      left: 50%;
      transform: translate(-50%, -50%);
      color: white;
      font-family: "Helvetica", Helvetica, sans-serif;
      text-align: center;
    }

    h1 {
      font-size: 144px;
    }

    p {
      font-size: 64px;
    }
  </style>
</head>

<body>
  <div class="center">
    <h1>Admin panel moved to academy.htb</h1>
    <br>
    <p>HTB{bru73_f0r_c0mm0n_p455w0rd5}</p>
  </div>
</body>
</html>
alley@kali:~$
```

Recursive Fuzzing

Try to repeat what you learned so far to find more files/directories. One of them should give you a flag. What is the content of the flag?

HTB{fuzz1n6_7h3_w3b!}

Sub-domain Fuzzing

Try running a sub-domain fuzzing test on 'inlanefreight.com' to find a customer sub-domain portal. What is the full domain of it?

Customer.inlanefreight.com

The screenshot shows the HTB Academy VHosts Fuzzing interface. The main terminal window displays the following output:

```
Session Actions Edit View Help
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
:: Filter  : Response size: 0

:: Progress: [4989/4989] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 4989 ::
alleg@kali:~$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ -u https://FUZZ.inlanefreight.com/
v2.1.0-dev

:: Method      : GET
:: URL         : https://FUZZ.inlanefreight.com/
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher    : Response status: 200-299,301,302,307,401,403,405,500

support [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 312ms]
my      [Status: 200, Size: 22266, Words: 2903, Lines: 316, Duration: 327ms]
my      [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 348ms]
blog    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 344ms]
ns3     [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 353ms]
customer [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 274ms]
:: Progress: [4989/4989] :: Job [1/1] :: 37 req/sec :: Duration: [0:00:36] :: Errors: 4983 ::
alleg@kali:~$ curl https://customer.inlanefreight.com
```

The interface also includes a sidebar with a 'Table of Contents' and a 'Skills Assessment' section. The bottom of the screen shows navigation buttons: 'Previous', 'Section 8 / 13', 'Next', and 'Mark Complete & Next'.

Try running a VHost fuzzing scan on 'academy.htb', and see what other VHosts you get. What other VHosts did you get?

Test.academy.htb


```
Session Actions Edit View Help
alley@kali:~$ sudo nano /etc/hosts
[sudo] password for alley:
alley@kali:~$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ \
-u http://154.57.164.65:30338/ \
-H "Host: FUZZ.academy.htb" \
-fs 0

Sub-domain Fuzzing
Try running a sub-domain fuzzing test on 'plane(freight.com)' to find a customer sub-domain portal.
What is the full domain of it?
Customer:plane(freight.com)

:: Method      : GET
:: URL         : http://154.57.164.65:30338/
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header      : Host: FUZZ.academy.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 0

autodiscover [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 189ms]
mail [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 190ms]
new [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 190ms]
smtp [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 190ms]
ns1 [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 191ms]
dns1 [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 177ms]
old [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 177ms]
www1 [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 177ms]
lists [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 179ms]
web [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 179ms]
static [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 179ms]
server [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 177ms]
img [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 178ms]
news [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 178ms]
portal [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 178ms]
api [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 178ms]
images [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 177ms]
dns [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 177ms]
www.blog [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 178ms]
backup [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 180ms]
sql [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 176ms]
www.forum [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 176ms]
intranet [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 177ms]
stats [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 178ms]
www.test [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 179ms]
host [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 178ms]
media [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 178ms]
video [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 176ms]
mail1 [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 176ms]
mx1 [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 176ms]
```

```
Session Actions Edit View Help
ricky [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1958ms]
webdisk.files [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1813ms]
www.webdesign [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1751ms]
wcz [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1266ms]
lolo [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 2808ms]
and [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1681ms]
elib [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 2727ms]
birmingham [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3349ms]
qb [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 5355ms]
www.analytics [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 4892ms]
:: Progress: [4989/4989] :: Job [1/1] :: 35 req/sec :: Duration: [0:00:35] :: Errors: 0 ::
alley@kali:~$ curl -s -H "Host: random.academy.htb" http://154.57.164.65:30338 | wc -c
986
alley@kali:~$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ \
-u http://154.57.164.65:30338/ \
-H "Host: FUZZ.academy.htb" \
-fs 986

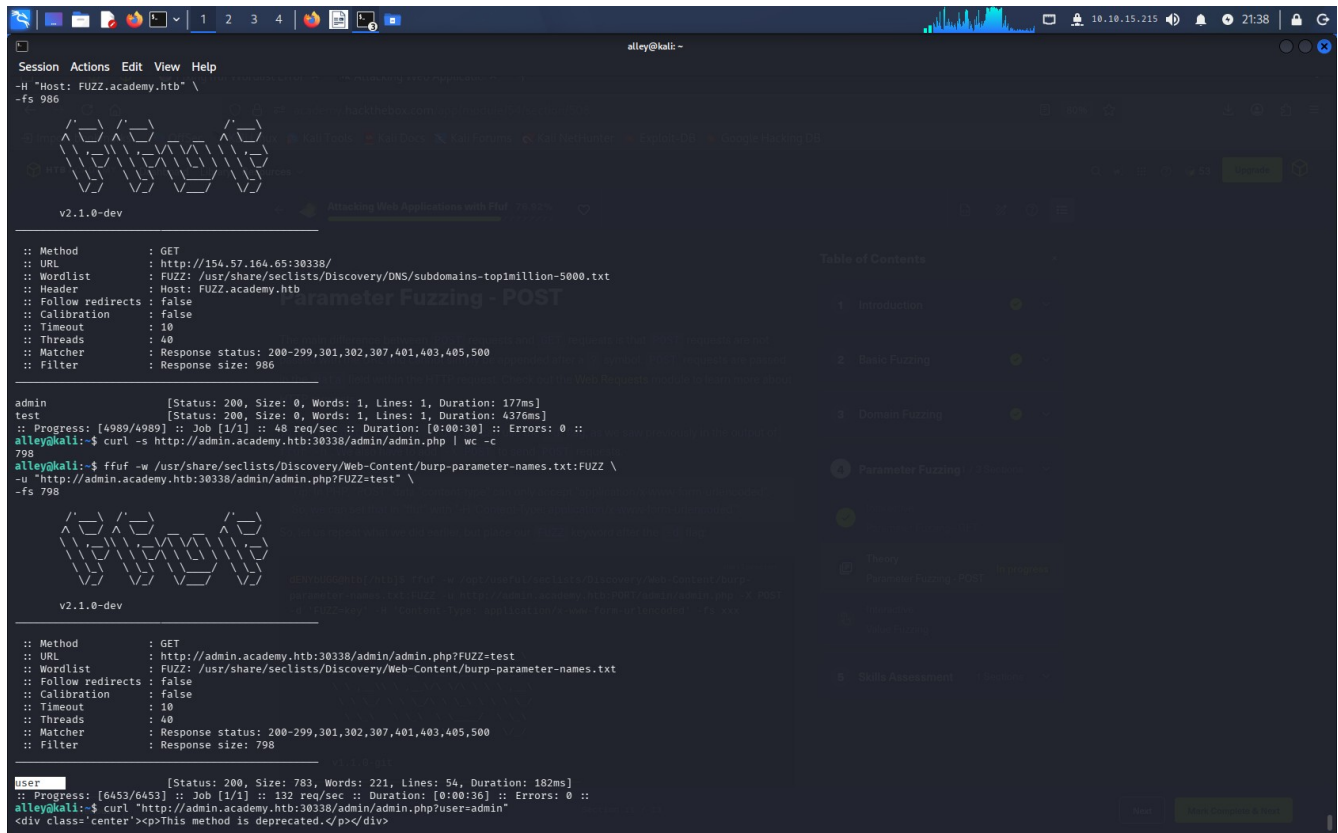
Sub-domain Fuzzing
Try running a sub-domain fuzzing test on 'plane(freight.com)' to find a customer sub-domain portal.
What is the full domain of it?
Customer:plane(freight.com)

:: Method      : GET
:: URL         : http://154.57.164.65:30338/
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header      : Host: FUZZ.academy.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 986

admin [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4978ms]
test [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4974ms]
:: Progress: [4989/4989] :: Job [1/1] :: 218 req/sec :: Duration: [0:00:26] :: Errors: 0 ::
alley@kali:~$
```

Using what you learned in this section, run a parameter fuzzing scan on this page. What is the parameter accepted by this webpage?

User



```
Session Actions Edit View Help
-H "Host: FUZZ.academy.htb" \
-fs 986

v2.1.0-dev

Attacking Web Applications with ffuf 0.5.0

:: Method      : GET
:: URL         : http://154.57.164.65:30338/
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header     : Host: FUZZ.academy.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout    : 10
:: Threads   : 40
:: Matcher   : Response status: 200-299,301,302,307,401,403,405,500
:: Filter    : Response size: 986

admin [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 177ms]
test  [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4376ms]
:: Progress: [4989/4989] :: Job [1/1] :: 48 req/sec :: Duration: [0:00:30] :: Errors: 0 ::
alley@kali:~$ curl -s http://admin.academy.htb:30338/admin/admin.php | wc -c
798
alley@kali:~$ ffuf -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ \
-u "http://admin.academy.htb:30338/admin/admin.php?FUZZ=test" \
-fs 798

v2.1.0-dev

:: Method      : GET
:: URL         : http://admin.academy.htb:30338/admin/admin.php?FUZZ=test
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout    : 10
:: Threads   : 40
:: Matcher   : Response status: 200-299,301,302,307,401,403,405,500
:: Filter    : Response size: 798

user [Status: 200, Size: 783, Words: 221, Lines: 54, Duration: 182ms]
:: Progress: [6453/6453] :: Job [1/1] :: 132 req/sec :: Duration: [0:00:36] :: Errors: 0 ::
alley@kali:~$ curl "http://admin.academy.htb:30338/admin/admin.php?user=admin"
<div class='center'><p>This method is deprecated.</p></div>
```

Try to create the 'ids.txt' wordlist, identify the accepted value with a fuzzing scan, and then use it in a 'POST' request with 'curl' to collect the flag. What is the content of the flag?

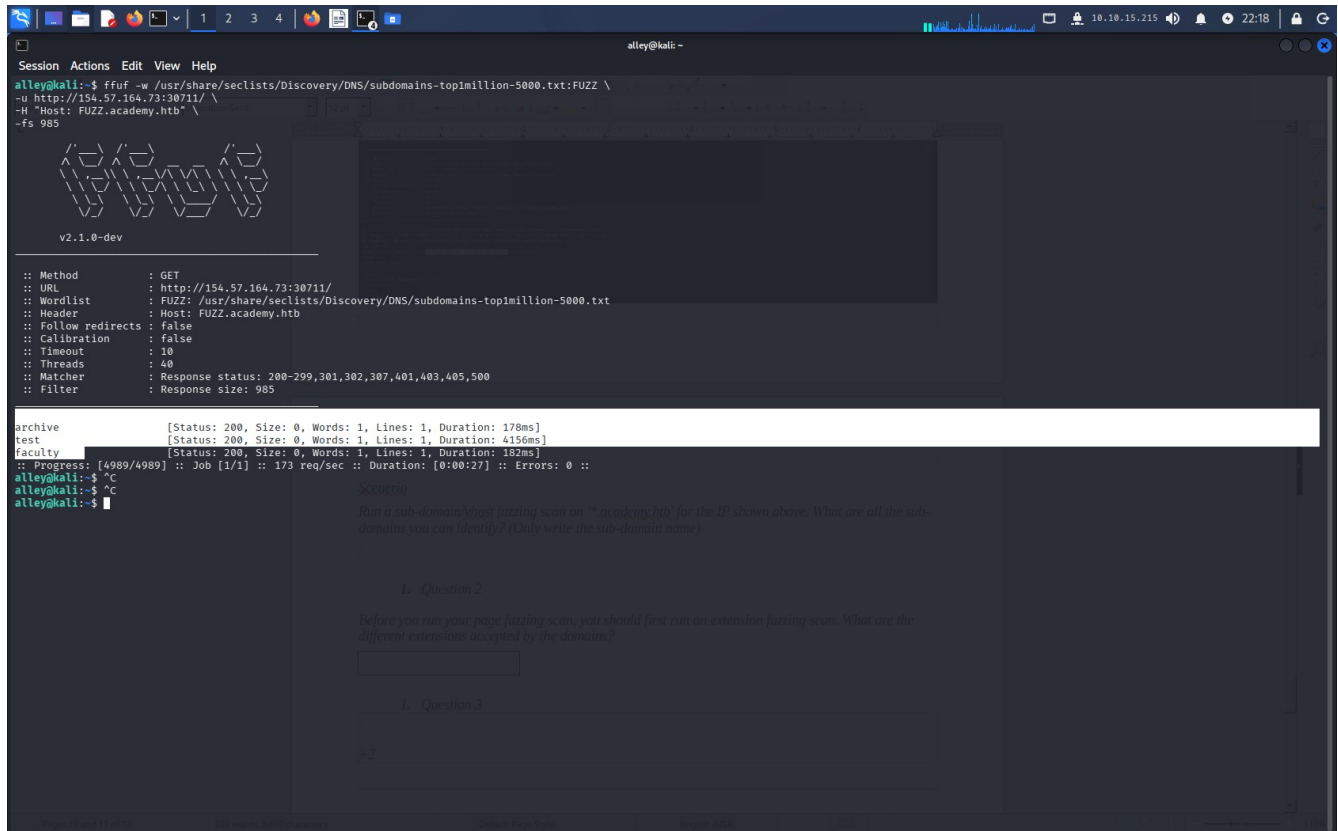
```
alley@kali: ~  
Session Actions Edit View Help  
</html>  
alley@kali:~$ for i in $(seq 1 1000); do echo $i >> ids.txt; done  
alley@kali:~$ head ids.txt  
1  
2  
3  
4  
5  
6  
7  
8  
9  
10  
alley@kali:~$ curl -s -X POST http://admin.academy.htb:30338/admin/admin.php \\\n-d "id=1" | wc -c  
768  
alley@kali:~$ ffuf -w ids.txt:FUZZ \\\n-u http://admin.academy.htb:30338/admin/admin.php \\\n-X POST \\\n-d "id=FUZZ" \\\n-H "Content-Type: application/x-www-form-urlencoded" \\\n-fs 768  
  
v2.1.0-dev  
  
:: Method : POST  
:: URL : http://admin.academy.htb:30338/admin/admin.php  
:: Wordlist : FUZZ: /home/alley/ids.txt  
:: Header : Content-Type: application/x-www-form-urlencoded  
:: Data : id=FUZZ  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter : Response size: 768  
  
73 [Status: 200, Size: 787, Words: 218, Lines: 54, Duration: 177ms]  
:: Progress: [1000/1000] :: Job [1/1] :: 150 req/sec :: Duration: [0:00:08] :: Errors: 0 ::  
alley@kali:~$ curl -X POST http://admin.academy.htb:30338/admin/admin.php \\\n-d "id=73" \\\n<div class='center'><p>HTB{p4r4m373r_fuzz1n6_15_k3y!}</p></div>  
<html>  
<!DOCTYPE html>  
  
<head>  
<title>HTB Academy</title>  
<style>  
*.  
html {
```

```
alley@kali: ~  
Session Actions Edit View Help  
</html>  
alley@kali:~$ for i in $(seq 1 1000); do echo $i >> ids.txt; done  
alley@kali:~$ head ids.txt  
1  
2  
3  
4  
5  
6  
7  
8  
9  
10  
alley@kali:~$ curl -s -X POST http://admin.academy.htb:30338/admin/admin.php \\\n-d "id=1" | wc -c  
768  
alley@kali:~$ ffuf -w ids.txt:FUZZ \\\n-u http://admin.academy.htb:30338/admin/admin.php \\\n-X POST \\\n-d "id=FUZZ" \\\n-H "Content-Type: application/x-www-form-urlencoded" \\\n-fs 768  
  
v2.1.0-dev  
  
:: Method : POST  
:: URL : http://admin.academy.htb:30338/admin/admin.php  
:: Wordlist : FUZZ: /home/alley/ids.txt  
:: Header : Content-Type: application/x-www-form-urlencoded  
:: Data : id=FUZZ  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter : Response size: 768  
  
73 [Status: 200, Size: 787, Words: 218, Lines: 54, Duration: 177ms]  
:: Progress: [1000/1000] :: Job [1/1] :: 150 req/sec :: Duration: [0:00:08] :: Errors: 0 ::  
alley@kali:~$ curl -X POST http://admin.academy.htb:30338/admin/admin.php \\\n-d "id=73" \\\n<div class='center'><p>HTB{p4r4m373r_fuzz1n6_15_k3y!}</p></div>  
<html>  
<!DOCTYPE html>  
  
<head>  
<title>HTB Academy</title>  
<style>  
*.  
html {
```

Scenerio

Run a sub-domain/vhost fuzzing scan on '*.academy.htb' for the IP shown above. What are all the sub-domains you can identify? (Only write the sub-domain name)

archive test faculty



```
alleg@kali:~$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ \
-u http://154.57.164.73:30711/ \
-H 'Host: FUZZ.academy.htb' \
-fs 985

:: Method      : GET
:: URL         : http://154.57.164.73:30711/
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header     : Host: FUZZ.academy.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher    : Response status: 200-299,301,302,307,401,403,405,500
:: Filter     : Response size: 985

archive      [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 178ms]
test         [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4156ms]
faculty      [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 182ms]
:: Progress: [4989/4989] :: Job [1/1] :: 173 req/sec :: Duration: [0:00:27] :: Errors: 0 ::
alleg@kali:~$ ^C
alleg@kali:~$ ^C
alleg@kali:~$
```

Question 2

Before you run your page fuzzing scan, you should first run an extension fuzzing scan. What are the different extensions accepted by the domains?

.php .php7 .phps

```
Session Actions Edit View Help
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500

:: Progress: [43/43] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 43 ::
alleykali:~$ sudo nano /etc/hosts
[sudo] password for alley:
alleykali:~$ ffuf -w /usr/share/seclists/Discovery/Web-Content/web-extensions.txt:FUZZ \
-u http://faculty.academy.htb:30711/indexFUZZ \
-fs 0

v2.1.0-dev

Question 3
:: Method : GET
:: URL : http://faculty.academy.htb:30711/indexFUZZ
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/Web-Content/web-extensions.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
:: Filter : Response size: 0

phps [Status: 403, Size: 287, Words: 20, Lines: 10, Duration: 5082ms]
:: Progress: [43/43] :: Job [1/1] :: 5 req/sec :: Duration: [0:00:08] :: Errors: 0 ::
alleykali:~$ ffuf -w /usr/share/seclists/Discovery/Web-Content/common.txt:FUZZ \
-u http://faculty.academy.htb:30711/index.FUZZ

v2.1.0-dev

Question 4
:: Method : GET
:: URL : http://faculty.academy.htb:30711/index.FUZZ
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500

php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 177ms]
phps [Status: 403, Size: 287, Words: 20, Lines: 10, Duration: 179ms]
:: Progress: [4750/4750] :: Job [1/1] :: 218 req/sec :: Duration: [0:00:25] :: Errors: 0 ::
```

Question 3

One of the pages you will identify should say 'You don't have access!'. What is the full page URL?

```
alleg@kali: ~$ curl http://faculty.academy.htb:PORT/courses/linux-security.php7
url: (3) URL rejected: Port number was not a decimal number between 0 and 65535
alleg@kali: ~$ curl http://faculty.academy.htb:PORT/courses/linux-security.php7
url: (3) URL rejected: Port number was not a decimal number between 0 and 65535
alleg@kali: ~$ curl http://faculty.academy.htb:32500/courses/linux-security.php7
<div class="center"><p>You don't have access!</p></div>
html>
DOCTYPE html>
head>
<title>HTB Academy</title>
<style>
*{
html {
margin: 0;
padding: 0;
border: 0;
}

html {
width: 100%;
height: 100%;
}

body {
width: 100%;
height: 100%;
position: relative;
background-color: #151D28;
}

.center {
width: 100%;
height: 50%;
margin: 0;
position: absolute;
top: 50%;
left: 50%;
transform: translate(-50%, -50%);
color: white;
font-family: "Helvetica", Helvetica, sans-serif;
text-align: center;
}

h1 {
font-size: 144px;
}

p {
font-size: 64px;
}
</style>
</head>
body>
body>
/html>alleg@kali: ~$
```

Question 4

In the page from the previous question, you should be able to find multiple parameters that are accepted by the page. What are they?


```
Session Actions Edit View Help
# on at least 3 different hosts.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 177ms]
# on at least 3 different hosts.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 177ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 177ms]
# .php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 178ms]
index.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 178ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 833ms]
# or send a letter to Creative Commons, 171 Second Street, .php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 1836ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 1836ms]
# directory-list-2.3-small.txt [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 2842ms]
# directory-list-2.3-small.txt.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 2844ms]
# directory-list-2.3-small.txt.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 2845ms]
# .php7 [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 2844ms]
# Attribution-Share Alike 3.0 License. To view a copy of this.php7 [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 3847ms]
# Copyright 2007 James Fisher.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 3847ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 3846ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 3847ms]
# Attribution-Share Alike 3.0 License. To view a copy of this.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 3847ms]
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 3847ms]
# .php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 3847ms]
# .php7 [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 3849ms]
# Suite 300, San Francisco, California, 94105, USA..php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4852ms]
# Suite 300, San Francisco, California, 94105, USA..php7 [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4852ms]
# Attribution-Share Alike 3.0 License. To view a copy of this [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4803ms]
# Copyright 2007 James Fisher.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4805ms]
# Copyright 2007 James Fisher.php7 [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4805ms]
# This work is licensed under the Creative Commons.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4806ms]
# .php7 [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4809ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4809ms]
# Priority-ordered case-sensitive list, where entries were found.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4516ms]
# on at least 3 different hosts.php7 [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4517ms]
# .php7 [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4513ms]
# .phps [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4515ms]
index.php7 [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4513ms]
linux-security.php7 [Status: 200, Size: 774, Words: 223, Lines: 93, Duration: 184ms]
:: Progress: [67107/350656] :: Job [1/1] :: 208 req/sec :: Duration: [0:06:15] :: Errors: 3 ::
```

Question 5

Try fuzzing the parameters you identified for working values. One of them should return a flag. What is the content of the flag?


```
alley@kali: ~$ ffuf -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt -u https://faculty.academy.htb:30115/ -mc 200 -fs 42 -c -v
Session Actions Edit View Help
-o Write output to file
-d Directory path to store matched results to.
-of Output file format: Available formats: json, ejson, html, md, csv, ecsv (or, 'all' for all formats) (default: json)
-or Don't create the output file if we don't have results (default: false)

EXAMPLE USAGE:
Fuzz file paths from wordlist.txt, match all responses but filter out those with content-size 42.
Colored, verbose output.
ffuf -w wordlist.txt -u https://example.org/FUZZ -mc all -fs 42 -c -v

Fuzz Host-header, match HTTP 200 responses.
ffuf -w hosts.txt -u https://example.org/ -H "Host: FUZZ" -mc 200

Fuzz POST JSON data. Match all responses not containing text "error".
ffuf -w entries.txt -u https://example.org/ -X POST -H "Content-Type: application/json" \
-d '{"name": "FUZZ", "anotherkey": "anothervalue"}' -fr "error"

Fuzz multiple locations. Match only responses reflecting the value of "VAL" keyword. Colored.
ffuf -w params.txt:PARAM -w values.txt:VAL -u https://example.org/?PARAM=VAL -mr "VAL" -c

More information and examples: https://github.com/ffuf/ffuf

Encountered error(s): 1 errors occurred.
* stat /home/alley/Seclists/Discovery/Web-Content/burp-parameter-names.txt: no such file or directory

alley@kali:~$ ffuf -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ \
-u https://faculty.academy.htb:30115/courses/linux-security.php7 \
-X POST \
-d 'FUZZ=key' \
-H 'Content-Type: application/x-www-form-urlencoded' \
-fs 774

:: Method : POST
:: URL : http://faculty.academy.htb:30115/courses/linux-security.php7
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt
:: Header : Content-Type: application/x-www-form-urlencoded
:: Data : FUZZ=key
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
:: Filter : Response size: 774

user [Status: 200, Size: 780, Words: 223, Lines: 53, Duration: 183ms]
username [Status: 200, Size: 781, Words: 223, Lines: 53, Duration: 183ms]
:: Progress: [6453/6453] :: Job [1/1] :: 187 req/sec :: Duration: [0:00:47] :: Errors: 0 ::
alley@kali:~$
```